CATEGORY 1: Architectural Fundamentals & Enforcement Model

Goal: Determine if the tool provides preventive controls, detective controls, or observability only

Q1.1: Control Type Classification

"Is your tool a preventive control (blocks violations before they occur), detective control (identifies violations after they occur), or observability tool (provides visibility only)? Can you prevent—not just detect—unauthorized actions?"

What you're testing: Understanding of their security model and honest positioning

Good answers:

- ☑ "We provide [preventive/detective/observability] controls. Specifically: [explains mechanism]. For comprehensive coverage, customers need [lists complementary controls]."
- ☑ "We're detective-only. We cannot block actions, only alert. Prevention requires [specific technologies/approaches]."

Bad answers (RED FLAGS):

- 🚩 "We prevent all security violations" (Overpromise without technical explanation)
- 🚩 "Detection and prevention are essentially the same" (Fundamental misunderstanding)
- 🚩 Vague answers without technical specifics
- 🚩 Claims to be "all three" without explaining how

Follow-up questions:

- "Walk me through a specific scenario: An employee wants to send customer PII to an unauthorized AI endpoint. At what point in that workflow does your tool intervene? What technical mechanism stops or detects it?"
- "If I bypass your tool using [alternative method], what happens?"
- "Show me a live demo where you block an action before it completes."

Q1.2: Enforcement Point and Coverage

"Where in the technology stack does your enforcement/detection occur? Specifically, what access methods do you cover vs. what's out of scope?"

Coverage to test:

- Client-side (browser, desktop app, mobile app)

- Network-level (proxy, gateway, firewall)
- API layer (API gateway, authentication layer)
- Application-level (code libraries, SDKs)
- Endpoint (OS-level, process monitoring)
- Cloud infrastructure (CASB, cloud-native controls)

What you're testing: Understanding of their coverage gaps and blind spots

Good answers:

- ☑ "We operate at [specific layer]. We cover: [lists methods with percentages]. We do NOT cover: [lists gaps]. For complete coverage, customers deploy us alongside [compensating controls]."
- ☑ "We monitor 70-80% of typical data scientist workflows. The remaining 20-30% requires [specific tools]."

Bad answers (RED FLAGS):

- 🚩 "We cover all access methods" (Likely false)
- 🚩 "Most users don't use those other methods" (Ignores security risk)
- 🚩 Cannot enumerate specific gaps
- 🚩 Dismissive of uncovered attack vectors

Follow-up questions:

- "Create a table: List every way users could access AI models/data in our environment. For each, mark whether your tool provides visibility, detection, or prevention."
- "What percentage of potential data exfiltration paths do you cover?"
- "If users access AI via [curl, Python, mobile app, different browser], do you have visibility?"

Q1.3: Bypass Analysis

"What are the top 5 ways a determined user could bypass your tool? How would you detect those bypass attempts?"

What you're testing: Security maturity and honest threat modeling

Good answers:

- ☑ "Top bypass methods: [lists specific techniques]. Detection requires: [explains compensating controls needed]. We document these in our threat model and customer deployment guide."
- ☑ "Users can bypass by [method]. We detect via [mechanism] with [X]% reliability. However, sophisticated adversaries using [technique] would evade detection."

Bad answers (RED FLAGS):

- 🚩 "Our tool cannot be bypassed" (Unrealistic)
- 🚩 "We've never seen bypass attempts" (Lack of monitoring or dishonesty)
- 🚩 "That's not how users behave" (Doesn't address security risk)
- 🚩 Cannot enumerate specific bypass methods

Follow-up questions:

- "If a user disables/uninstalls your agent/extension/tool, what happens? How quickly do you detect it?"
- "Can users operate in 'stealth mode' or 'privacy mode' that avoids your monitoring?"
- "Show me your threat model document. Which attacks are in-scope vs. explicitly out-of-scope?"

Q1.4: Deployment Architecture Options

"What deployment models do you support: SaaS, on-premise, hybrid? Where does our data go in each model?"

What you're testing: Data sovereignty and control options

Good answers:

- ☑ "We offer: [lists models]. Data flows: [detailed diagram for each]. Customers choose based on regulatory requirements. For [HIPAA/FedRAMP/GDPR], we recommend [specific model]."
- ☑ "SaaS only, but data is processed in customer-selected regions with data residency guarantees. Here's our regional availability: [lists]."

Bad answers (RED FLAGS):

- 🚩 "SaaS only" without explaining data residency options
- 🚩 "Data stays in the US" (problem for GDPR, other regulations)
- 🚩 Cannot explain data flow differences between models
- 🚩 "On-premise available" but no customers actually using it (vaporware)

Follow-up questions:

- "For SaaS: Which cloud provider and regions? Can we specify?"
- "For on-premise: What's the deployment complexity? How many customers have actually deployed this way?"
- "For hybrid: What data stays on-premise vs. goes to cloud? Can we control this?"
- "Show me architecture diagrams for each deployment model with data classifications mapped."